

INCIDENT INVESTIGATION REPORT

2024 Financial Report — Zebrocy Dropper (APT28-Associated Phishing Intrusion)

LetsDefend SOC Simulation | DFIR Case Study | Prepared for Portfolio Use

Ediz YURDAGÜL | edizyurdagul@hotmail.com

Incident Title	2024 Financial Report — Zebrocy Dropper
Classification	True Positive — Trojan / Dropper (Execution Confirmed, C2 Not Confirmed)
Threat Family	Zebrocy / Strictor (Sednit / APT28-associated indicators)
Severity	High
Status	Contained
Target Account	LetsDefend (montague@letsdefend.io)
Incident Date	October 11, 2024 — approx. 02:24–05:52 UTC

1. Executive Summary

On October 11, 2024, the account `montague@letsdefend.io` received an email disguised as a legitimate financial-report notification, sent from `pavlodar.news@bk.ru`. The email referenced a password-protected archive (2024-financial-report.zip, password: infected) containing a Word-icon-disguised executable named 2024 Financial Report.exe. The recipient downloaded and ran this file, resulting in execution of a dropper identified as a Zebrocy variant — a toolset with documented ties to the Sednit/APT28 threat actor.

Static and reputation analysis confirmed the dropped executable as malicious (47/69 VirusTotal vendors, family label trojan.zebrocy/strictor). Host telemetry shows the dropper created a secondary file, `drvmmc.exe`, in a Temp subdirectory — however, that directory was found empty at the time of this review, meaning the secondary artifact's continued presence on disk could not be directly confirmed (see Section 5, Evidence Notes).

No successful outbound Command & Control (C2) communication or data exfiltration was confirmed within the evidence set reviewed for this report. The incident is classified as a contained compromise at the Execution/Discovery phase. Verdict: True Positive.

2. Incident Details & Timeline

Incident Date	October 11, 2024
Platform	LetsDefend SOC Simulation
Target Account	montague@letsdefend.io
Initial Access Vector	Phishing email with password-protected archive; file retrieved via browser download from external cloud storage (see Section 5)
Malicious File	2024 Financial Report.exe (Word-icon disguised)

Threat Classification	Trojan / Dropper
Threat Family	Zebrocy / Strictor / Sednit (47/69 VirusTotal detections)
Severity	High
Verdict	True Positive
Status	Contained — secondary payload presence not independently re-confirmed

Timeline Summary

Time (UTC)	Event
2024-10-11 02:24:00	Phishing email received from pavlodar.news@bk.ru, subject "2024 Financial Report"
2024-10-11 05:51:41	2024-financial-report.zip downloaded via chrome.exe from an external S3 URL
~05:51-05:52	Archive extracted; 2024-financial-report.zip and 2024-financial-report\ folder created under Downloads
2024-10-11 05:52:14	2024 Financial Report.exe executed (PID 4436, parent: explorer.exe)
Shortly after execution	Secondary file drvmmc.exe created under AppData\Local\Temp\1\

3. MITRE ATT&CK Mapping

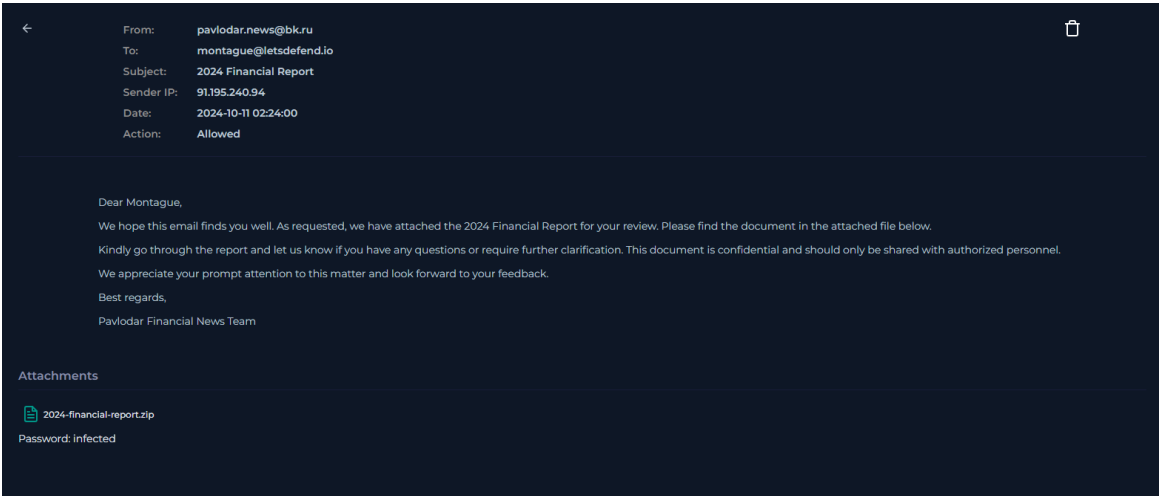
Tactic	Technique	Evidence
Initial Access	T1566.002 — Phishing: Spearphishing Link	Delivery log shows the archive was retrieved by chrome.exe from an external URL (S3 bucket), not saved directly as a mail-client attachment — see Section 5 for the distinction from the originally-assumed T1566.001
Defense Evasion	T1027 — Obfuscated/Password-Protected Files	Archive protected with password "infected" to evade content/attachment scanning at the mail gateway
Execution	T1204.002 — User Execution: Malicious File	User manually double-clicked 2024 Financial Report.exe (parent: explorer.exe)
Defense Evasion	T1036.005 — Masquerading: Match Legitimate Name or Location	Executable uses a Word document icon and a financial-report-themed filename to appear benign
Execution / Persistence (candidate)	T1059.003 — Windows Command Shell	Reported execution of cmd.exe /c SYSTEMINFO — see Section 5 for evidentiary caveat
Discovery	T1082 — System Information Discovery	Reported SYSTEMINFO execution for host/OS/patch-level enumeration — see Section 5

Command and Control	T1071.001 — Application Layer Protocol: Web Protocols	Reported outbound C2 attempt, reportedly blocked at the firewall — see Section 5
---------------------	--	--

4. Technical Analysis & Evidence

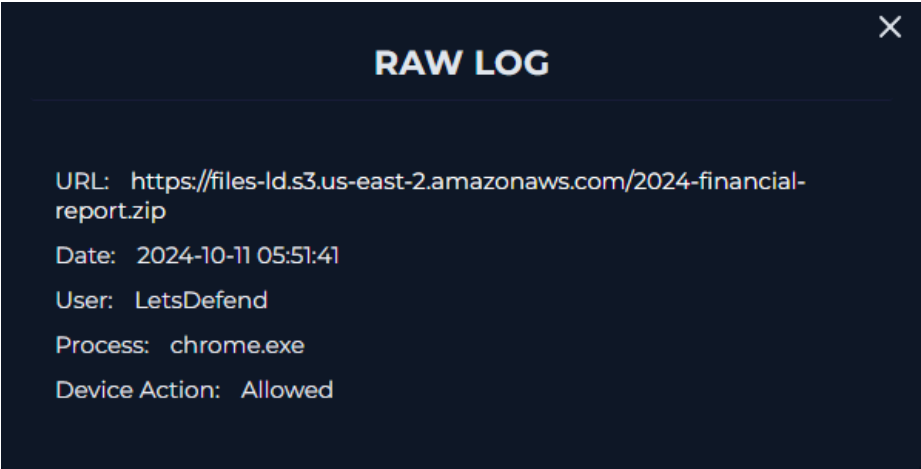
4.1 Delivery & Initial Access

The lure email impersonated a financial news contact, referencing a '2024 Financial Report' and instructing the recipient to review the attached, password-protected archive.

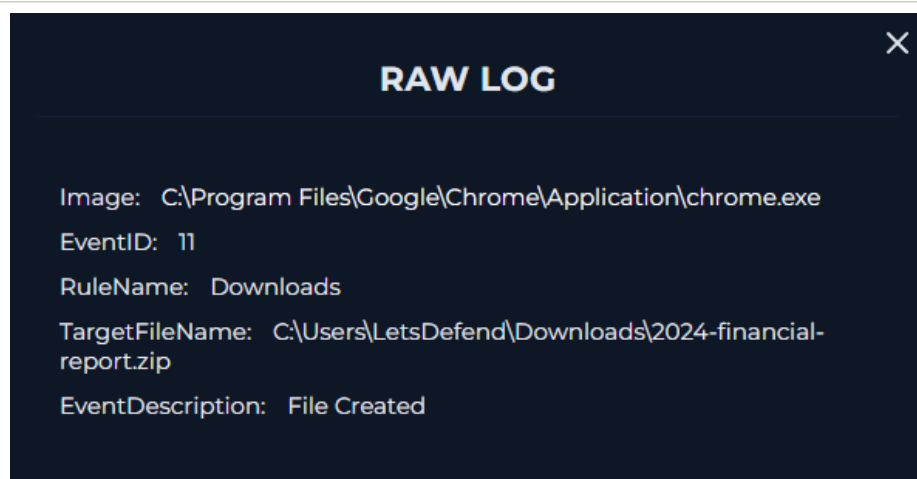


Phishing email — sender pavlodar.news@bk.ru, password-protected archive attachment, IP 91.195.240.94

Critically, the proxy/download log shows the actual file transfer occurred via chrome.exe retrieving the archive from an external cloud storage URL, not a native mail-client attachment save. This distinction matters for both the MITRE mapping (Section 3) and for understanding the true delivery chain — the email likely carried a hyperlink rather than a literal MIME attachment.



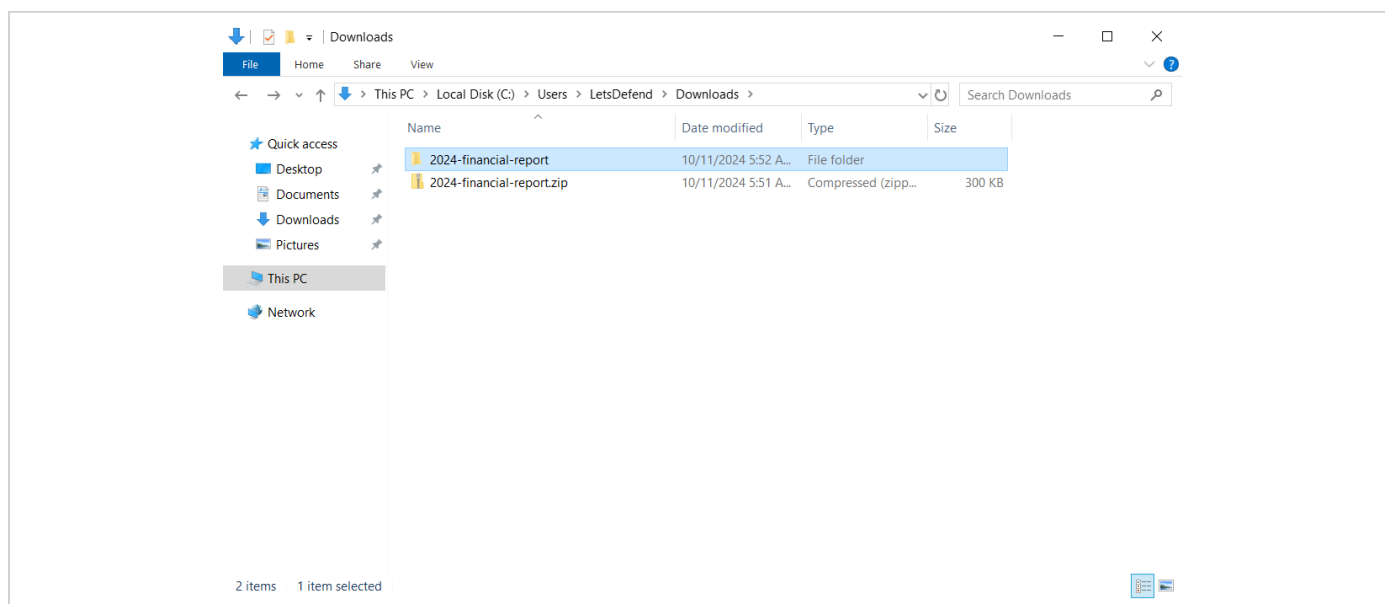
Raw log — chrome.exe downloading 2024-financial-report.zip from an external S3 URL at 05:51:41



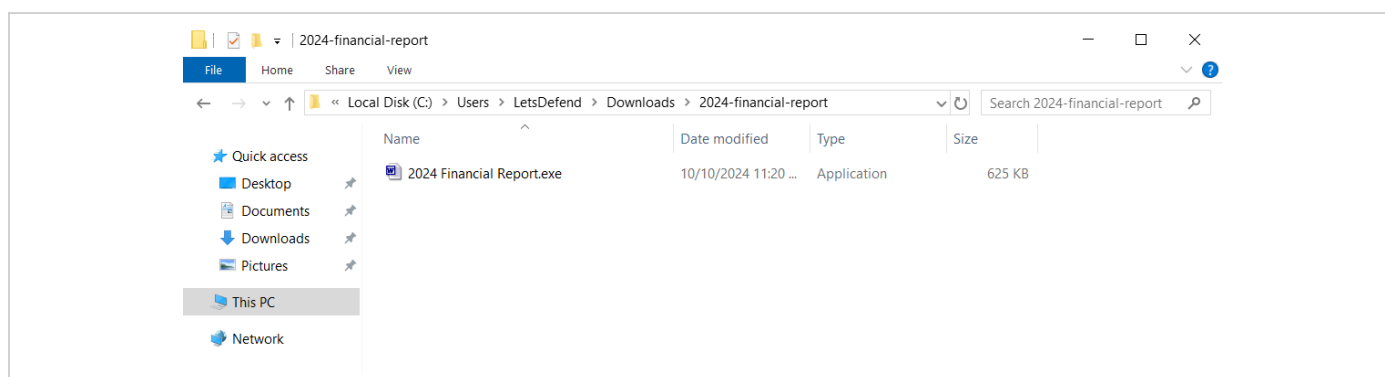
Raw log — File Created event for the downloaded archive in the Downloads folder

4.2 Extraction & Execution

The archive was extracted into a subfolder, revealing a single file disguised with a Microsoft Word icon despite being a Windows executable.

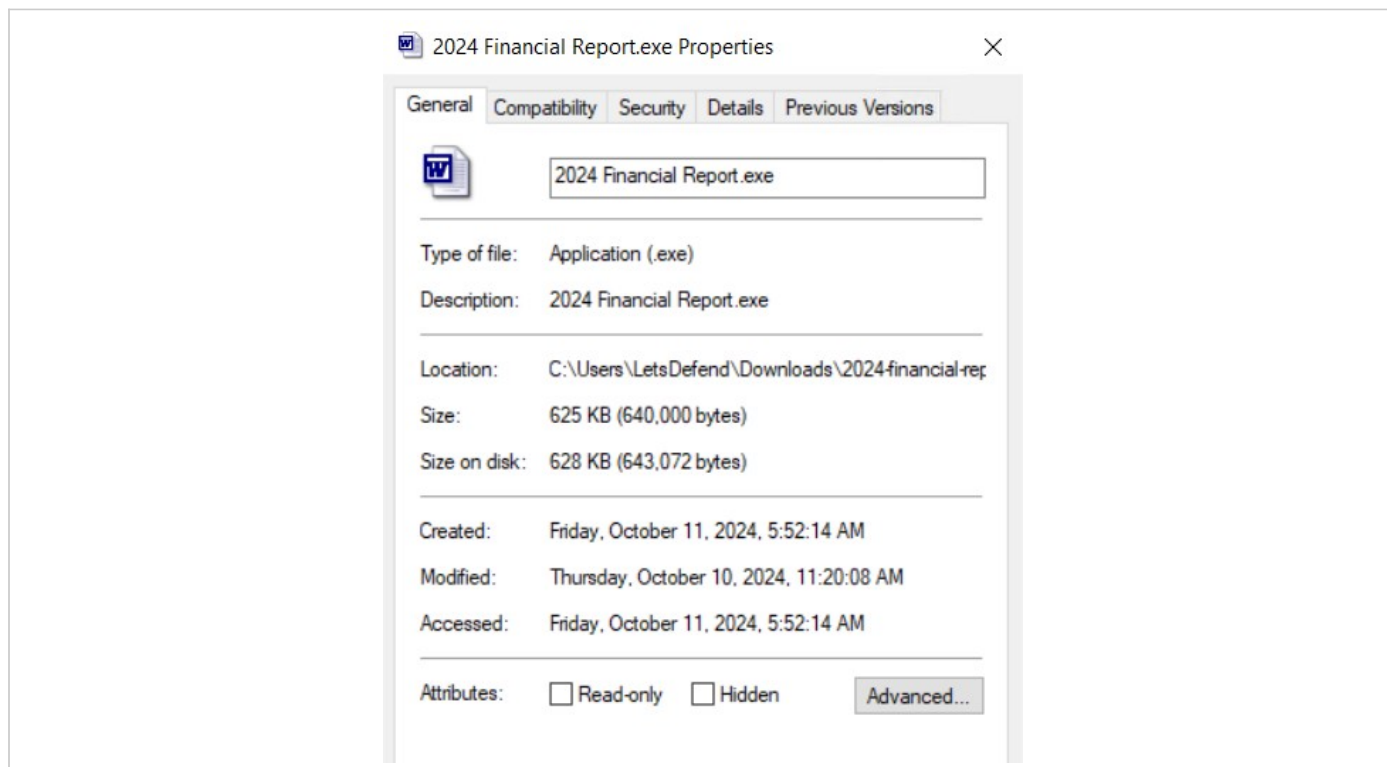


Downloads folder — the extracted 2024-financial-report folder alongside the original archive



Extracted folder contents — 2024 Financial Report.exe, 625 KB, displaying a Word document icon

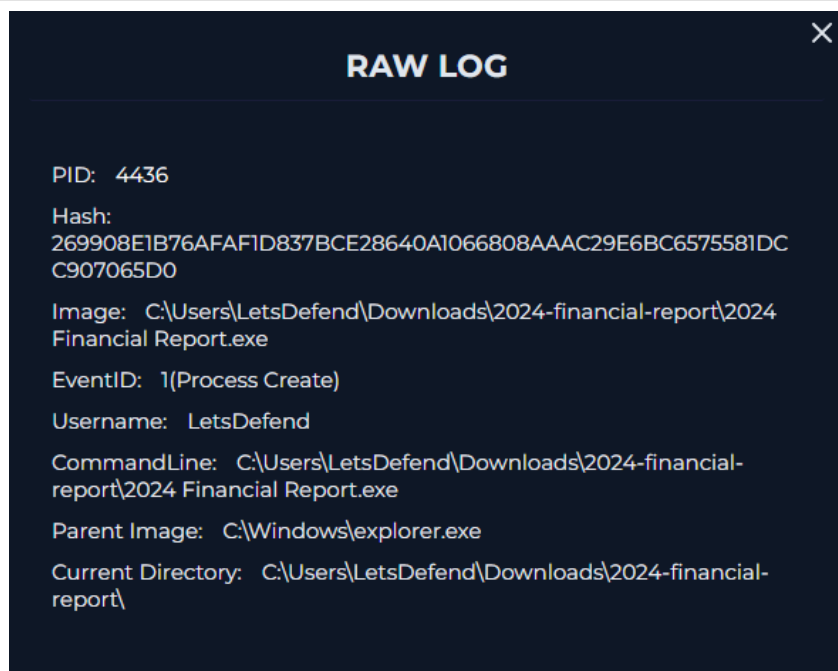
File properties confirm this is a Windows executable (not a document) despite its icon and display name, and show a Modified timestamp (Oct 10, 11:20 AM) predating the Created/Accessed timestamps on this host (Oct 11, 5:52 AM) by roughly one day — consistent with the binary having been compiled/prepared by the attacker prior to deployment, with no evidence of timestamping (artificially altered timestamps) observed.



File properties — Type: Application (.exe), despite the Word-report display name and icon

Process-creation telemetry confirms direct user execution:

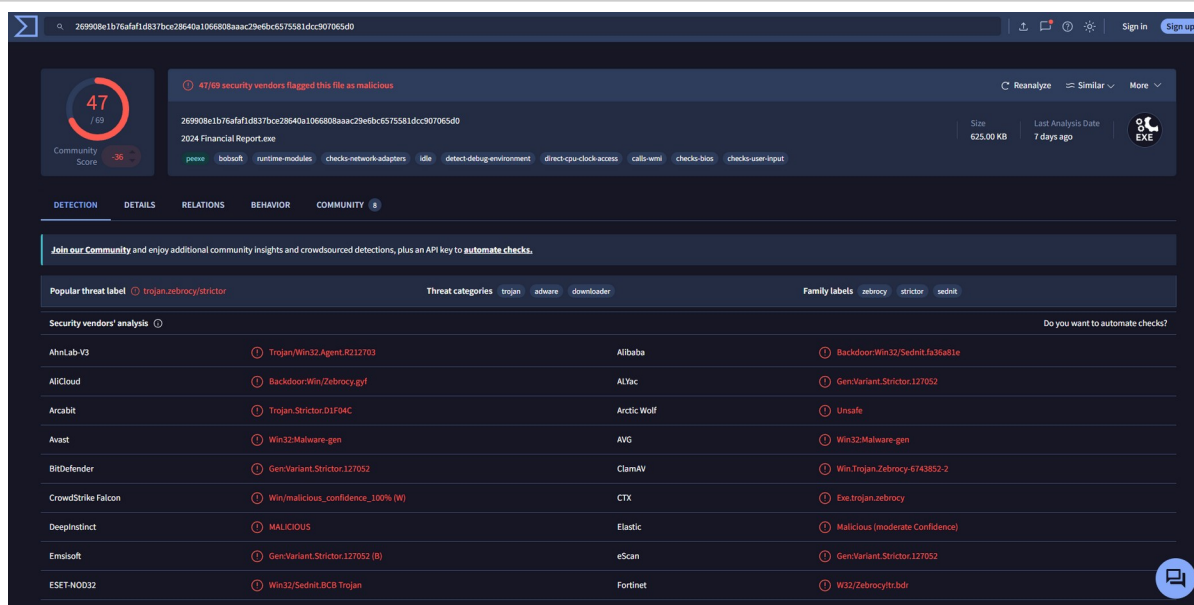
```
PID           : 4436
Image          : C:\Users\LetsDefend\Downloads\2024-financial-report\2024 Financial Report.exe
Hash (SHA256)  : 269908E1B76AF1D837BCE28640A1066808AAAC29E6BC6575581DCC907065D0
ParentImage    : C:\Windows\explorer.exe
Username       : LetsDefend
```



Raw log — Process Create event for 2024 Financial Report.exe (PID 4436), launched directly from Explorer

4.3 Reputation Analysis

The dropper's hash was submitted for reputation analysis, independently confirming the file as a known, catalogued threat.

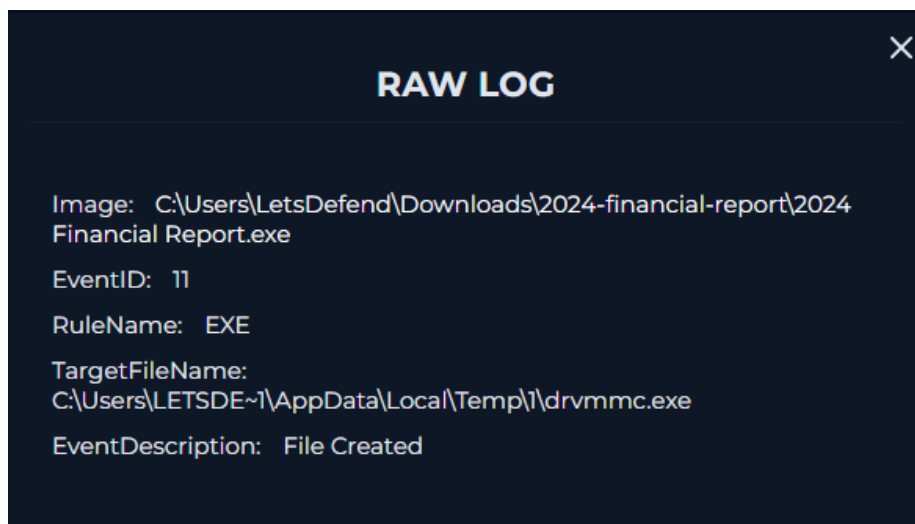


VirusTotal — 47/69 vendors flag the file as malicious, family: trojan.zebrocy/strictor

- Detection rate: 47 out of 69 security vendors flagged the file as malicious.
- Popular threat label: trojan.zebrocy/strictor.
- Family labels: zebrocy, strictor, sednit. Categories: trojan, adware, downloader.
- The Zebrocy/Sednit family has well-documented historical associations with APT28 ("Fancy Bear") espionage campaigns, raising the assessed severity of this "financial report" lure beyond a generic commodity trojan.

4.4 Secondary Payload Artifact

Shortly after execution, the malicious process created a secondary file in a per-user temp subdirectory:

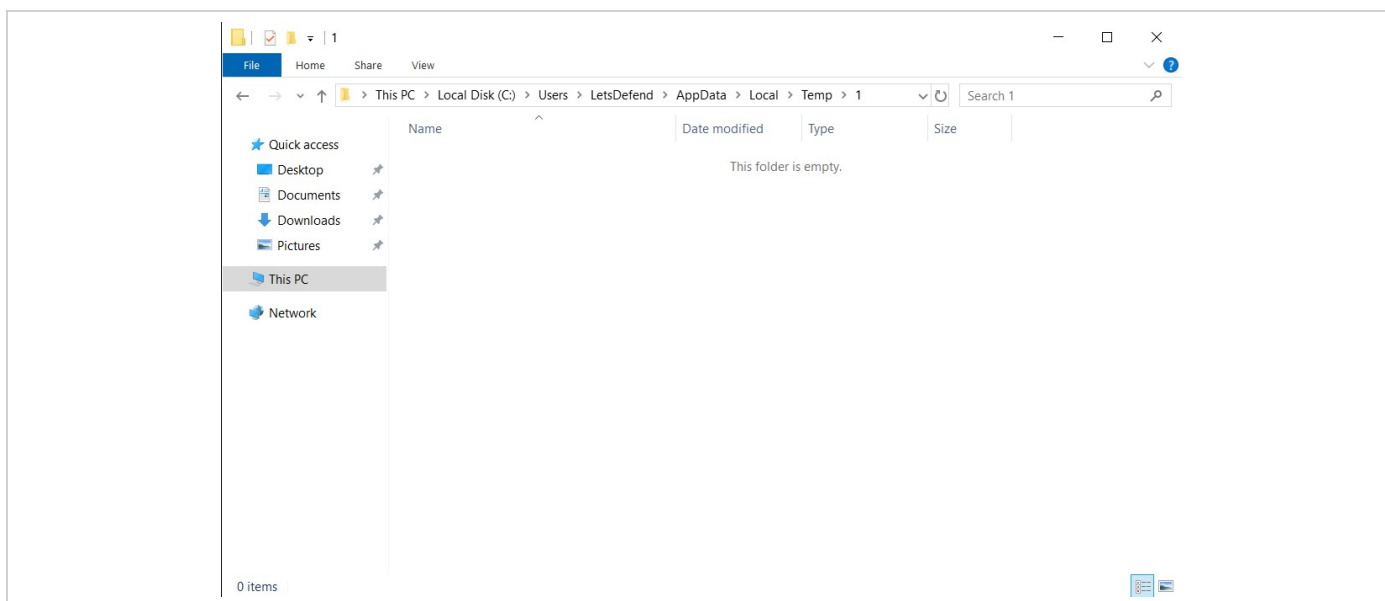


Raw log — File Created event: 2024 Financial Report.exe writing drvmmc.exe to AppData\Local\Temp\1\

5. Evidence Notes & Scope

For transparency, here is what this review does and does not independently confirm from the evidence set provided:

Secondary payload not found on disk at time of review: Despite the File Created event for drvmmc.exe, the target directory (AppData\Local\Temp\1\) was found empty upon inspection. Two explanations are plausible: (1) the dropper exhibits self-deleting stage-2 behavior after execution — a known evasion pattern in Zebrocy-family tooling, intended to minimize the forensic footprint — or (2) the artifact was already removed by endpoint security or prior remediation before this screenshot was captured. This distinction materially changes the containment picture and should be resolved before final closure; it is flagged here rather than silently assumed.



AppData\Local\Temp\1\ — folder found empty at time of review, despite the earlier File Created event for drvmmc.exe

Discovery (SYSTEMINFO) and C2-block claims are reported, not re-verified here: The investigation narrative supplied for this review states that cmd.exe /c SYSTEMINFO was executed and that a subsequent C2 connection attempt was blocked at the firewall. Neither claim is backed by a screenshot in the evidence set examined for this report (no process-execution log for SYSTEMINFO, no firewall/network log showing a blocked outbound connection). These findings are retained in the MITRE mapping and narrative as reported, but should be corroborated with the corresponding process and firewall/network logs before this report is treated as fully evidenced.

Delivery mechanism re-classified: The original write-up assumed the ZIP was delivered as a direct email attachment (T1566.001). Proxy/download logs instead show chrome.exe fetching the archive from an external cloud-storage URL. This report maps the technique as T1566.002 (Spearphishing Link) accordingly; confirming this with the email's raw source/headers would close out the remaining ambiguity.

6. Indicators of Compromise (IOCs)

Type	Value	Context
Sender Email	pavlodar.news@bk.ru	Phishing sender
Sender IP	91.195.240.94	Phishing mail source
Malicious Archive	2024-financial-report.zip (password: infected)	Password-protected delivery archive
Delivery URL	https://files-ld.s3.us-east-2.amazonaws.com/2024-financial-report.zip	External host from which the archive was downloaded
Malicious Executable	2024 Financial Report.exe	Zebrocy dropper, disguised with a Word icon
Dropper SHA256	269908E1B76AFAF1D837BCE28640A1066808AAAC29E6BC6575581DCC907065D0	Hash of the primary dropper, 47/69 on VirusTotal
Process ID	4436	PID of the dropper at execution
Secondary Artifact	drvmmc.exe	Stage-2 file reportedly dropped; not found on disk at review time
Secondary Artifact Path	C:\Users\LETSDE~1\AppData\Local\Temp\1\drvmmc.exe	Reported location of the stage-2 artifact
Threat Label	trojan.zebrocy/strictor (47/69 on VT)	VirusTotal

		community verdict
--	--	----------------------

7. Containment, Eradication & Remediation

Actions Taken

- Host isolation: the affected endpoint was isolated from the network given confirmed execution of a known-malicious binary and an unresolved secondary-artifact status.
- Artifact cleanup: the archive, extracted folder, and dropper executable were removed from Downloads; forensic copies retained.
- Temp directory re-verification: AppData\Local\Temp\1\ was re-checked and confirmed empty (see Section 5) — recommend a full disk/timeline sweep to locate drvmmc.exe elsewhere or confirm self-deletion.
- Blocklisting: dropper hash submitted to EDR for quarantine signature coverage; sender email (pavlodar.news@bk.ru) and sender IP (91.195.240.94) blocked at the email gateway.
- Credential hygiene: password reset recommended for the affected account as a precaution.

Outstanding / Recommended Follow-Up

- Pull and review the process-execution log for cmd.exe /c SYSTEMINFO to confirm the Discovery-phase finding with direct evidence.
- Pull and review the firewall/network log for the reported blocked C2 attempt, including the destination IP/domain, to fully close the Command & Control mapping.
- Review the original email's raw source/headers to confirm whether the ZIP was a true MIME attachment or a hyperlink, finalizing the Initial Access technique mapping.
- Run a full endpoint timeline sweep (MFT/USN journal or EDR file-activity history) to determine whether drvmmc.exe was deleted by the malware itself, by security tooling, or during remediation.

8. Lessons Learned & Recommendations

- Password-protected archives remain a reliable gateway-evasion technique; mail security policy should flag or sandbox them by default rather than allowing outright.
- Icon spoofing (a Word icon on an .exe) is trivial to produce and easy for users to miss — endpoint controls that warn on double-extension or icon/extension mismatches add meaningful friction against this exact lure.
- A File Created event is not proof of persistence. Always re-verify artifact presence on disk before asserting a dropped payload remains active — self-deleting stage-2 tooling is a known Zebrocy-family behavior and should be explicitly checked for, not assumed away.
- Every claim in an incident report should be traceable to a specific piece of evidence. Where a finding is carried over from a prior analyst step without a corresponding log in hand, label it as such rather than presenting it with the same confidence as a directly-verified artifact.
- Attribution-adjacent findings (Zebrocy/Sednit/APT28 indicators) should prompt a broader environment-wide hunt for related indicators, even when the specific incident appears contained.